Foundations of Operating Systems, Networking, Infrastructure & Cybersecurity

SOC Analyst Handbook

Document Type: Enterprise Technical Handbook
Target Audience: Tier 1/2 SOC Analysts, System Administrators, Security Architects
Version: 1.0 (Audit-Ready)
Security Classification: Internal Use Only

Table of Contents

Chapter 1: Operating Systems

Foundation of Operating Systems (Enterprise Context)

An Operating System (OS) is not merely the interface a user interacts with; in an enterprise context, it is the resource manager and the first line of defense. It abstracts hardware complexity and enforces security policies via Access Control Lists (ACLs) and privileges.

Figure 1.1: OS Architecture Layers

```
      [User Space] <-- Applications, Shells, Utilities | [System
Call Interface] | [Kernel Space] <-- Process Mgmt,
      Memory Mgmt, File System, Device Drivers | [Hardware] <-- CPU,
RAM, Disk, NIC
```

OS as Resource Manager

CPU Management: The scheduler determines which process runs. Security implication: Malware (e.g., cryptominers) attempts to hijack high CPU cycles without detection.

Memory Management: Allocates RAM to processes. Security implication: Buffer overflow attacks occur when apps write beyond allocated memory boundaries.

Windows 10/11 in the Enterprise

Usage: The standard endpoint for 80%+ of corporations. Deployed via SCCM/Intune.

Security Architecture: Uses SAM (Security Account Manager), LSASS (Local Security Authority Subsystem Service), and BitLocker.

> **SOC Monitoring Focus:** Watch specifically for tampering with **lsass.exe** (credential dumping) and unexpected changes to Registry keys (Persistence).

Golden Images

Definition: A pre-configured template of an OS (Windows/Linux) containing approved software, security patches, and configurations.

Enterprise Mandate: Prevents "drift." If a machine is infected, IT does not troubleshoot; they re-image from the Golden Image to restore a trusted state.

Chapter 2: Linux Fundamentals

Linux Overview & Distributions

Linux powers 90%+ of the world's servers and cloud infrastructure. Unlike Windows, it is modular.

Category	Distributions	Enterprise Use Case
Red Hat (RHEL)	RHEL, CentOS, Fedora	Corporate servers, banking systems, rigorous stability.
Debian	Debian, Ubuntu, Kali	Web servers (Ubuntu), Penetration Testing (Kali).

Bash & PowerShell Scripting

Automation: Used for bulk user creation, log parsing, and patching.

Security Risk: "Living off the Land" (LotL) attacks. Attackers use native Bash/PowerShell tools to blend in.

The Linux Kernel & Daemons

Kernel: The core interface between software and hardware. Vulnerabilities here (e.g., Dirty COW) grant root access.

Daemons: Background services (names end in 'd', e.g., sshd, httpd). SOC analysts must audit running daemons to detect unauthorized listeners.

Chapter 3: Windows Server Fundamentals

Server Roles

A Windows Server is defined by its **Roles** (primary function, e.g., Active Directory Domain Services) and **Features** (support functions, e.g., BitLocker).

Virtual vs. Physical Servers

Physical (Bare Metal): Used for high-performance databases (SQL) or Hypervisors.

Virtual: The standard. Allows rapid snapshotting and recovery. SOCs must treat VM snapshots as potential data leakage points if not encrypted.

Chapter 4: Server Types & Services

Active Directory (AD)

Definition: Microsoft's directory service for identity management.

SOC Focus: The "Crown Jewels." Monitoring for Brute Force (Event 4625), Privilege Escalation, and Golden Ticket attacks.

DNS Server

Purpose: Translates hostnames to IPs.

Attack Vector: DNS Tunneling (exfiltrating data over DNS protocol). SOCs monitor for high-volume DNS requests to anomalous domains.

Web Server (IIS / Apache / Nginx)

Purpose: Hosts web applications.

Common Attacks: SQL Injection, XSS, DDoS. Monitored via WAF (Web Application Firewall) logs.

Chapter 5: Computer Hardware

Memory & Caching

RAM (Volatile): Data is lost on reboot. Critical for forensics (Cold Boot Attacks).

Cache (L1/L2/L3): Extremely fast CPU memory. Side-channel attacks (Spectre/Meltdown) exploit how CPUs speculatively read cache.

Why SOC Cares About Memory

Fileless malware resides **only** in RAM, never writing to the hard drive. Traditional AV often misses this; EDR (Endpoint Detection & Response) is required to inspect memory spaces.

Chapter 6: Virtualization

Hypervisors

Figure 6.1: Hypervisor Types

```
      TYPE 1 (Bare Metal): TYPE 2 (Hosted): [ VM ][ VM ] [ VM ][ VM
] [ Hypervisor (ESXi) ] [ Hypervisor (VMware
      Workstation) ] [ Hardware ] [ Host OS (Windows) ] [ Hardware ]
```

Type 1: Enterprise standard (VMware ESXi, Hyper-V).

Security Risks: VM Escape (attacker moves from Guest VM to Host Hypervisor).

Chapter 7: Containerization

Containers vs. Virtualization

Feature	Virtual Machines (VM)	Containers (Docker/Kubernetes)
Isolation	Hardware-level (Full OS)	OS-level (Shared Kernel)
Boot Speed	Minutes	Milliseconds
Security	High (Strong isolation)	Medium (Shared kernel risk)

Kubernetes (K8s)

Enterprise Overview: Orchestrates container deployment.

Security Risks: Misconfigured K8s dashboards often allow unauthenticated root access to the entire cluster.

Chapter 8: Networking Basics

OSI vs. TCP/IP Models

OSI Layer	TCP/IP Layer	Protocol Examples	PDU (Data Unit)
7. Application	Application	HTTP, DNS, SMTP	Data
6. Presentation		SSL/TLS (Encryption)	Data
5. Session		NetBIOS, RPC	Data
4. Transport	Transport	TCP, UDP	Segment
3. Network	Internet	IP, ICMP	Packet
2. Data Link	Network Access	Ethernet, ARP	Frame
1. Physical		Cables, WiFi	Bit

Wireshark

Definition: The standard network protocol analyzer.

SOC Usage: Used to analyze PCAP (Packet Capture) files to reconstruct attack traffic (e.g., seeing the exact SQL injection payload sent over HTTP).

IP Addressing & Subnetting

CIDR: Classless Inter-Domain Routing (e.g., /24). Essential for defining firewall rules.

Private IP Ranges (RFC 1918): 10.x.x.x, 172.16.x.x, 192.168.x.x. These are not routable on the internet.

Chapter 9: Network Components & Services

VPN (Virtual Private Network)

Role: Encrypts tunnel between remote user and corporate network.

SOC Visibility: Monitoring "Impossible Travel" (User logs in from NY, then London 5 mins later).

Load Balancer

Role: Distributes traffic across servers.

Security Role: Often acts as the first line of defense against DDoS attacks.

Chapter 10: Network Operations

Ports & Connections

Key Ports to Monitor:

- **21 (FTP):** Clear text file transfer (Insecure).
- **22 (SSH):** Secure remote access.
- **23 (Telnet):** Clear text remote access (HIGH RISK).
- **80/443 (HTTP/HTTPS):** Web traffic.
- **3389 (RDP):** Remote Desktop (Common ransomware entry point).

Understanding Network Diagrams

SOC analysts must read topology maps to understand where a firewall sits relative to a compromised server (North-South vs East-West traffic).

Chapter 11: Enterprise Network Services

Email (Exchange / O365)

Primary Threat Vector: 90% of attacks start with Phishing.

SOC Tools: Email Gateways (Proofpoint, Mimecast) to analyze headers for spoofing (SPF/DKIM/DMARC failures).

NTP (Network Time Protocol)

Security Importance: Kerberos authentication fails if clocks are out of sync by >5 minutes. Accurate logs depend entirely on synchronized NTP.

Chapter 12: Modern Security Architecture

Zero Trust Architecture

Definition: "Never Trust, Always Verify." No user or device is trusted just because they are "inside" the network.

Implementation: Micro-segmentation and continuous MFA (Multi-Factor Authentication).

SOC Telemetry Sources

Figure 12.1: The SOC Visibility Triad

```
      [ EDR ] (Endpoint Data) + [ NDR ] (Network Data) + [ SIEM ]
(Log Aggregation & Correlation)
```

Chapter 13: Information Security Foundations

CIA Triad

- **Confidentiality:** Encryption, Access Controls.
- **Integrity:** Hashing, Digital Signatures.
- **Availability:** Redundancy, Backups, DDoS protection.

IAAA

Identification: Claiming an identity (Username).

Authentication: Proving the identity (Password/Biometric).

Authorization: What resources can you access? (Permissions).

Accounting: Logging what was done (Audit Trails).

Chapter 14: Risk Management

Risk Responses

1. **Avoid:** Stop the activity causing risk.
2. **Transfer:** Insurance or outsourcing.
3. **Mitigate:** Implement controls (firewalls, patching).
4. **Accept:** Acknowledge risk and monitor (cost of fix > cost of loss).

Risk Register

A formal document tracking all identified risks, their severity (Likelihood x Impact), and owner. SOC data feeds this by providing real-world threat frequency.

Chapter 15: Cryptography

Symmetric vs Asymmetric

Symmetric (AES): Same key encrypts and decrypts. Fast. Used for bulk data.

Asymmetric (RSA/ECC): Public key encrypts, Private key decrypts. Used for key exchange and signatures.

Case Study: Heartbleed

A vulnerability in OpenSSL (2014) allowed attackers to read memory of a server, potentially stealing private keys. This highlighted the need for rigorous library patching.

Chapter 16: Artificial Intelligence & Gen-AI

Generative AI & LLMs

Concept: Models like GPT predict the next token in a sequence based on vast training data.

Enterprise Risk: Data leakage. Employees pasting proprietary code or PII into public LLMs.

AI in Cybersecurity

Defense: AI models detect anomalies in user behavior (UEBA) faster than static rules.

Offense: Attackers use AI to generate perfect phishing emails and polymorphic malware code.

Chapter 17: Attack Surface & Malware

Malware Types

- **Ransomware:** Encrypts data for extortion.
- **Worm:** Self-propagating, needs no user interaction (e.g., WannaCry).
- **Trojan:** Disguised as legitimate software.
- **Wiper:** Destroys data purely for sabotage (e.g., NotPetya).

Phishing Variants

Vishing: Voice phishing.

Smishing: SMS phishing.

Whaling: Targeting C-suite executives.

Chapter 18: Hackers & Security Testing

Vulnerability Assessment vs. Penetration Testing

Aspect	Vuln Assessment	Penetration Test
Method	Automated Scanning (Nessus)	Manual Exploitation
Goal	List all flaws	Achieve a specific objective (e.g., Domain Admin)
Frequency	Continuous/Weekly	Annually/Bi-annually

Chapter 19: MITRE ATT&CK Framework

Overview

A globally accessible knowledge base of adversary tactics and techniques. It moves the conversation from "What is the hash?" to "What is the behavior?"

The Matrix (Enterprise Usage)

SOCs use MITRE to map detections. Example: Mapping an alert for "PowerShell downloading a file" to **T1059 (Command and Scripting Interpreter)**.

Chapter 20: Case Study - Pyeongchang 2018

Olympic Destroyer Attack

Timeline: During the opening ceremony of the 2018 Winter Olympics.

Technique: The malware wiped domain controllers, disabling WiFi and gates.

False Flags: The code contained North Korean and Chinese fingerprints, but was attributed to Russia (Sandworm) as retaliation for doping bans.

Lesson: Attribution is difficult; focus on resilience.

Chapter 21: Attack Groups & Vectors

Unit 8200 & APTs

Advanced Persistent Threats (APTs) are nation-state backed groups. They have high resources and patience.

Insider Threat

Malicious (disgruntled employee) or Accidental (user clicks link). Often the hardest to detect because the access is legitimate.

Chapter 22: Famous Hackers

Kevin Mitnick

The "father" of social engineering. Demonstrated that the human element is the weakest link.

Equation Group

Widely suspected to be tied to the NSA. Known for extremely sophisticated toolsets (like those leaked by Shadow Brokers which led to EternalBlue).
